Dispositif de réponse aux incidents de sécurité

AgriSouss SARL — PME agricole fictive, Souss-Massa (Maroc)

Contenu	Politique de réponse aux incidents · 3 playbooks (BEC, rançongiciel, site web) · kit d'exercice sur table · fiches réflexes
Référentiels	NIST SP 800-61 r2 (phases) et r3 (2025, profil CSF 2.0) · SANS PICERL · RFC 3227 · lois marocaines 09-08, 05-20, 07-03
Auteur	Mohamed Elansari — élève ingénieur en cybersécurité, Universiapolis Agadir
Version / date	1.0 — 2026-10
Classification	Projet de portfolio — entreprise, personnes et incidents fictifs

Avertissement : document pédagogique à visée uniquement défensive. Les éléments juridiques reflètent la lecture des textes publics par l'auteur et ne constituent pas un avis juridique ; ils doivent être validés par un juriste, la CNDP ou la DGSSI avant tout usage réel. Les diagrammes de décision sont fournis en source Mermaid (texte) dans ce PDF.

Sommaire

Introduction et périmètre 4

Objet du document . . . 4
Contexte de l'entreprise (hypothèses) . . . 4
Référentiels utilisés . . . 4
Correspondance des phases . . . 5
Limites et avertissements . . . 5

Politique de réponse aux incidents de sécurité 6

1. Objet et champ d'application . . . 6
2. Rôles et responsabilités . . . 6
3. Niveaux de gravité . . . 7
4. Escalade et circuit d'alerte . . . 7
5. Communication . . . 8
6. Gestion des preuves et chaîne de possession . . . 9
7. Registre, retour d'expérience et amélioration . . . 9

Playbook A — Hameçonnage et compte Google Workspace compromis (BEC) 10

1. Déclencheurs et sources de détection . . . 10
2. Triage (15 premières minutes) . . . 10
3. Arbre de décision . . . 11
4. Confinement . . . 11
5. Éradication . . . 11
6. Rétablissement . . . 11
7. Preuves à collecter . . . 12
8. Modèles de communication . . . 12
9. Check-list post-incident . . . 13
10. Indicateurs (KPI) . . . 13

Playbook B — Rançongiciel sur un poste ou sur le partage de fichiers (NAS) 14

1. Déclencheurs et sources de détection . . . 14
2. Triage (premières minutes — agir vite) . . . 14
3. Arbre de décision . . . 15
4. Confinement . . . 15
5. Éradication . . . 15
6. Rétablissement . . . 15
7. Preuves à collecter (ordre de volatilité) . . . 16
8. Modèles de communication . . . 16

9. Check-list post-incident . . . 17
10. Indicateurs (KPI) . . . 17

Playbook C — Compromission du site e-commerce (défiguration, web shell, fuite de données clients) 18

1. Déclencheurs et sources de détection . . . 18
2. Triage . . . 18
3. Arbre de décision . . . 19
4. Confinement . . . 19
5. Éradication . . . 19
6. Rétablissement . . . 19
7. Preuves à collecter . . . 20
8. Modèles de communication . . . 20
9. Check-list post-incident . . . 21
10. Indicateurs (KPI) . . . 21

Kit d'exercice sur table — « Récolte chiffrée » (rançongiciel) 22

1. Fiche d'identité de l'exercice . . . 22
2. Guide de l'animateur . . . 22
3. Scénario et injects . . . 22
4. Questions transverses aux participants . . . 23
5. Grille d'évaluation . . . 24
6. Exemple de rapport post-exercice (RETEX) . . . 24

Fiches réflexes (à imprimer et afficher) 26

FICHE RÉFLEXE A — Courriel piégé / compte Google piraté . . . 27
FICHE RÉFLEXE B — Rançongiciel (fichiers chiffrés, note de rançon) . . . 28
FICHE RÉFLEXE C — Site e-commerce piraté . . . 29

Introduction et périmètre

Objet du document

Ce dossier rassemble le dispositif de réponse aux incidents de sécurité de **AgriSouss SARL**, PME agricole **fictive** de la région Souss-Massa (environ 15 salariés). Il complète le projet GRC (analyse de risques et politique de sécurité) bâti sur la même entreprise fictive. Il s'agit d'un **projet de portfolio** : l'entreprise, les personnes, les adresses et les incidents sont inventés.

Le dossier contient :

- une **politique de réponse aux incidents** (rôles, gravité, escalade, communication, preuves) ;
- trois **playbooks** opérationnels : hameçonnage et compte Google compromis (BEC), rançongiciel sur poste ou partage de fichiers, compromission du site e-commerce PHP ;
- un **kit d'exercice sur table** (tabletop) pour le scénario rançongiciel, avec un rapport post-exercice d'exemple **simulé** ;
- une **fiche réflexe** imprimable d'une page par playbook.

Contexte de l'entreprise (hypothèses)

> **Lien avec le projet GRC.** L'audit GRC décrit AgriSouss **au moment de l'audit** (comptes Gmail/Drive grand public, aucune sauvegarde testée, pas d'informaticien, paiement à la livraison). Ce dossier décrit l'entreprise **environ 12 mois plus tard**, après le plan d'action de l'audit : messagerie professionnelle Google Workspace sur le domaine de l'entreprise, NAS sauvegardé (actions A04 et suivantes), un informaticien polyvalent désigné référent incidents, et un paiement par carte ajouté via une page hébergée. Les écarts entre les deux projets sont donc voulus.

Élément	Hypothèse retenue
Activité	Négoce d'intrants agricoles (engrais, semences) et, depuis peu, vente de produits du terroir (agrumes, huile d'argan) ; B2B et vente en ligne
Effectif	~15 personnes : gérant, administration/comptabilité (3), commercial (3), logistique/station (6), 1 informaticien polyvalent, stagiaires ponctuels
Messagerie	Google Workspace (Gmail, Drive, Meet), domaine `agrisouss.example`
Site web	Boutique PHP / MariaDB chez un hébergeur externe (hébergement mutualisé ou VPS géré), paiement à la livraison majoritaire ; paiement par carte ajouté après l'audit GRC, délégué à une page de paiement hébergée (type CMI)
Postes	7 à 8 PC Windows 10/11 (dont 2 portables), 1 NAS de partage de fichiers au bureau, Wi-Fi bureau, imprimante réseau
Sauvegardes	NAS sauvegardé chaque nuit sur disque USB + copie hebdomadaire hors site (hypothèse à vérifier en exercice)
Sécurité	Antivirus Microsoft Defender, pas de SOC, pas de SIEM, 1 informaticien interne + prestataire externe sous contrat de maintenance
Assurance	Pas de police cyber au moment de la rédaction (point d'amélioration)

Référentiels utilisés

- **NIST SP 800-61 Rev. 2** (2012), *Computer Security Incident Handling Guide* : cycle en quatre phases — Préparation ; Détection et analyse ; Confinement, éradication et rétablissement ; Activité post-incident.
- **NIST SP 800-61 Rev. 3** (avril 2025), *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. La Rev. 3 remplace la Rev. 2 et ne décrit plus un cycle propre : elle range la réponse aux incidents dans les six fonctions du **NIST CSF 2.0** (Govern, Identify, Protect, Detect, Respond, Recover). Ce dossier garde la structure en phases de la Rev. 2 / SANS parce qu'elle est plus simple pour une PME, et indique à chaque fois la fonction CSF 2.0 correspondante.
- **SANS PICERL** : Preparation, Identification, Containment, Eradication, Recovery, Lessons learned.
- **RFC 3227** : ordre de volatilité des preuves.

- Cadre marocain : **loi 09-08** (données personnelles, CNDP), **loi 05-20** (cybersécurité, DGSSI / maCERT), **loi 07-03** (articles 607-3 à 607-11 du Code pénal, atteintes aux systèmes de traitement automatisé de données).

Correspondance des phases

NIST 800-61 r2	SANS PICERL	NIST CSF 2.0 (800-61 r3)	Dans ce dossier
Préparation	Preparation	Govern, Identify, Protect	Politique, sauvegardes, contacts, exercices
Détection et analyse	Identification	Detect, (Respond : analyse)	Déclencheurs, triage, arbre de décision
Confinement, éradication, rétablissement	Containment, Eradication, Recovery	Respond (mitigation), Recover	Étapes C / E / R des playbooks
Activité post-incident	Lessons learned	Identify (Improvement), Govern	Check-list post-incident, retour d'expérience

Limites et avertissements

- Contenu **uniquement défensif**. Aucune technique offensive n'est décrite.
- Les éléments juridiques sont une **lecture d'étudiant** des textes publics, pas un avis juridique. Ils doivent être validés par un avocat ou par la CNDP / DGSSI avant tout usage réel.
- Les noms de menus de la console Google Workspace changent régulièrement et certaines fonctions (outil d'enquête, journaux Gmail détaillés) dépendent de l'édition souscrite. Les chemins indiqués sont à vérifier sur la console réelle.
- Les diagrammes de décision sont fournis en **source Mermaid** (rendue graphiquement sur GitHub ou tout éditeur compatible). Dans le PDF, ils apparaissent sous forme de **source texte**, car le script de génération n'embarque pas de moteur de rendu Mermaid.

Politique de réponse aux incidents de sécurité

Référence	Version	Date	Propriétaire	Approbation
AGS-POL-IR-01	1.0	2026-10	Responsable informatique	Gérant d'AgriSouss SARL

1. Objet et champ d'application

Cette politique définit comment AgriSouss SARL détecte, traite, communique et tire les leçons des incidents de sécurité de l'information. Elle s'applique à tous les salariés, stagiaires et prestataires, et à tous les actifs : comptes Google Workspace, postes de travail, NAS, réseau du bureau, site e-commerce et sa base de données, téléphones utilisés pour le travail.

Événement : fait observable (alerte antivirus, courriel suspect, lenteur). **Incident** : événement qui compromet ou menace la confidentialité, l'intégrité ou la disponibilité d'une information ou d'un service, ou qui viole la politique de sécurité. Tout incident est un événement ; tout événement n'est pas un incident.

Principes :

1. **Signaler vite, sans crainte.** Un salarié qui a cliqué sur un lien ou ouvert une pièce jointe le signale immédiatement. Aucune sanction n'est prise pour un signalement de bonne foi ; la sanction concerne la dissimulation.
2. **Protéger d'abord les personnes et l'activité**, puis les preuves, puis le confort technique.
3. **Documenter tout** dans le registre d'incidents (date, heure, auteur, action).
4. **Ne jamais payer de rançon** sans décision écrite du gérant après avis juridique ; la position par défaut est le refus (arguments dans le playbook B et dans LEARN.md).

2. Rôles et responsabilités

Rôle	Titulaire (fictif)	Suppléant	Missions principales
Responsable de l'incident (RI)	Informaticien interne	Prestataire externe	Pilote technique, tient le registre, décide du confinement immédiat
Directeur de crise	Gérant	Responsable administratif et financier (RAF)	Décisions métier, budget, communication externe, plainte
Prestataire IT externe	Société de maintenance sous contrat	—	Renfort technique, réinstallation, analyse
Hébergeur web	Fournisseur d'hébergement	—	Journaux serveur, instantanés, restauration, blocage
Référent données personnelles	RAF	Gérant	Évalue l'impact sur les données clients/salariés, prépare l'éventuelle démarche CNDP
Conseil juridique	Avocat externe	—	Obligations légales, plainte, contrats, rançon
Salariés	Tous	—	Détecter, signaler, appliquer les consignes

Matrice RACI

R = réalise, A = rend des comptes (un seul A par ligne), C = consulté, I = informé.

Activité	Gérant	RI (IT interne)	Prestataire IT	Hébergeur	Référent données	Avocat	Salariés
Signaler un événement	I	I	—	—	—	—	R
Qualifier et classer la gravité	C	A/R	C	—	C	—	—
Confinement immédiat (isoler PC, bloquer compte)	I	A/R	R	R (site)	—	—	C
Décider l'arrêt d'un service métier (site, NAS)	A	R	C	C	C	—	I
Collecte et conservation des preuves	I	A/R	R	R (journaux)	—	C	—

Activité	Gérant	RI (IT interne)	Prestataire IT	Hébergeur	Référent données	Avocat	Salariés
Éradication et restauration	I	A	R	R (site)	—	—	—
Évaluer l'impact sur les données personnelles	C	C	—	C	A/R	C	—
Démarche CNDP / information des personnes	A	C	—	—	R	C	—
Signalement maCERT / plainte police	A	R	C	—	—	C	—
Communication aux clients et partenaires	A/R	C	—	—	C	C	I
Communication interne	A	R	—	—	—	—	I
Retour d'expérience et plan d'actions	A	R	C	C	C	—	I

3. Niveaux de gravité

La gravité est fixée par le RI lors du triage, puis révisée à chaque point de situation. En cas de doute entre deux niveaux, on prend le **plus élevé**.

Niveau	Nom	Critères (au moins un)	Exemples	Délai de prise en charge	Escalade
S1	Critique	Arrêt de l'activité ; chiffrement de plusieurs postes ou du NAS ; fuite avérée de données clients ou bancaires ; fraude financière en cours	Rançongiciel sur le NAS, base clients publiée, virement frauduleux	Immédiat, 24 h/24	Gérant appelé immédiatement ; prestataire mobilisé ; avocat sous 24 h
S2	Élevé	Compte à privilèges ou compte du gérant/compta compromis ; site défiguré ou web shell ; un poste chiffré isolé	Compte Gmail de la comptable piraté, page d'accueil défigurée	< 1 h ouvrée	Gérant informé < 1 h
S3	Modéré	Compte standard compromis sans fraude constatée ; malware bloqué mais exécuté ; vol d'un PC chiffré	Mot de passe saisi sur une fausse page, MFA active	< 4 h ouvrées	Gérant informé le jour même
S4	Faible	Tentative bloquée, sans impact	Courriel d'hameçonnage signalé sans clic	< 1 jour ouvré	Synthèse mensuelle

Facteurs aggravants qui font monter d'un niveau : données personnelles de plus de 100 personnes concernées, données de paiement, implication d'un partenaire ou d'un client B2B, couverture médiatique ou publique, récurrence.

4. Escalade et circuit d'alerte

1. Le salarié signale par **téléphone** au RI (pas seulement par courriel : la messagerie peut être compromise). Numéro affiché sur chaque poste et dans la fiche réflexe.
2. Le RI ouvre une entrée dans le **registre d'incidents** (tableur hors ligne + copie papier en S1), qualifie et classe.
3. S1/S2 : le RI appelle le gérant ; si injoignable sous 15 min, le RAF. Le prestataire IT est appelé selon les termes du contrat (vérifier le délai d'intervention contractuel).
4. Points de situation : S1 toutes les 2 h, S2 deux fois par jour, jusqu'à clôture.
5. Canal de crise hors bande : **groupe WhatsApp/Signal « Crise AgriSouss »** créé à l'avance avec gérant, RI, RAF, prestataire, plus une liste papier des numéros. On n'utilise pas un compte Google potentiellement compromis pour coordonner la crise.

Annuaire de crise (à tenir à jour, une copie papier dans le coffre du bureau) : gérant, RI, RAF, prestataire IT (numéro astreinte), hébergeur (support + numéro de contrat), banque (service fraude), avocat, assureur

éventuel, maCERT/DGSSI, police judiciaire.

5. Communication

5.1 Interne

- Un seul porte-parole interne (gérant), messages préparés par le RI.
- Message factuel : ce qui se passe, ce qu'on attend des salariés, ce qu'il ne faut pas faire (ne pas éteindre/rallumer, ne pas rebrancher, ne pas parler à l'extérieur).
- Pas de détails techniques inutiles, pas de recherche de coupable.

5.2 Clients, partenaires, fournisseurs

- Décidée par le gérant, après avis du référent données et, si besoin, de l'avocat.
- Prévenir **rapidement** les partenaires exposés (ex. : ils ont reçu des courriels frauduleux depuis notre domaine ou des demandes de changement de RIB).
- Ne jamais promettre ce qu'on ne sait pas (« aucune donnée n'a été touchée ») avant la fin de l'analyse. Dire ce qu'on sait, ce qu'on fait, ce que la personne peut faire, et quand on reviendra vers elle.
- Les modèles de messages sont dans chaque playbook.

5.3 Autorités : obligatoire ou recommandé ?

Cette section distingue ce qui est, selon notre lecture, **obligatoire** pour une PME privée et ce qui est **recommandé**. À valider par un juriste.

Destinataire	Base	Situation d'AgriSouss	Statut
CNDP (Commission nationale de contrôle de la protection des données à caractère personnel)	Loi 09-08 : obligation de sécurité des traitements (art. 23), déclaration ou autorisation préalable des traitements, droits des personnes	La loi 09-08 ne contient pas, à notre connaissance, d'obligation générale et explicite de notifier une violation de données dans un délai fixé, à la différence de l'art. 33 du RGPD. Une réforme de la loi est discutée.	**Fortement recommandé** de contacter la CNDP en cas de fuite de données personnelles, et d'informer les personnes concernées quand elles courent un risque (fraude, hameçonnage ciblé). Vérifier l'état du droit et les délibérations récentes de la CNDP au moment de l'incident.
RGPD (UE)	Art. 3(2) : s'applique si l'on cible des personnes situées dans l'UE (vente en ligne vers l'UE)	Possible si la boutique livre ou cible des clients européens	Si applicable : notification à l'autorité compétente sous 72 h et information des personnes en cas de risque élevé. À faire analyser par l'avocat.
DGSSI / maCERT (CERT national)	Loi 05-20 et décret 2-21-406 : obligation de déclarer les incidents pour les administrations, établissements publics, infrastructures d'importance vitale (IIV) et certains opérateurs	AgriSouss n'est ni administration ni IIV	**Non obligatoire, recommandé.** Signalement volontaire utile : maCERT peut aider à qualifier une menace, et le signalement améliore la connaissance nationale des attaques. Coordonnées à vérifier sur le site de la DGSSI.
Police judiciaire / parquet	Loi 07-03 (art. 607-3 et suivants du Code pénal) ; escroquerie	Intrusion, rançongiciel, fraude au virement	**Recommandé**, et souvent **exigé en pratique** par la banque (contestation de virement) et par un assureur. Déposer plainte avec les preuves conservées.
Banque	Contrat bancaire	Virement frauduleux	**Urgent** : appeler le service fraude immédiatement ; les chances de rappel des fonds baissent très vite.

Destinataire	Base	Situation d'AgriSouss	Statut
Assureur	Contrat	Si une police cyber est souscrite	Selon contrat : délai de déclaration souvent court, et l'assureur peut imposer ses prestataires.
CMI / prestataire de paiement	Contrat commerçant, PCI DSS	Si la page de paiement ou des données de carte peuvent être concernées	**Contractuel** : prévenir le prestataire sans délai.

6. Gestion des preuves et chaîne de possession

Objectif : pouvoir comprendre l'attaque, la prouver (plainte, assurance, litige) et ne pas détruire d'indices en voulant réparer.

Règles :

1. **Ne pas éteindre** un poste suspect sans raison : l'isoler du réseau (câble, Wi-Fi, mode avion). Exception : chiffrement en cours et impossibilité d'isoler, voir playbook rançongiciel.
2. Collecter dans l'**ordre de volatilité** (RFC 3227) : mémoire et connexions actives, puis disque, puis journaux distants (Google Workspace, hébergeur), puis sauvegardes et supports d'archive.
3. Travailler sur des **copies** ; calculer une empreinte **SHA-256** de chaque fichier ou image au moment de la collecte et la noter.
4. Photographier les écrans (note de rançon, défiguration) avec date et heure visibles.
5. Exporter les journaux cloud **tôt** : leur durée de rétention est limitée (elle dépend de l'édition Google Workspace et de l'offre d'hébergement).
6. Stocker les preuves sur un support dédié, étiqueté, rangé sous clé ; accès limité au RI et au gérant.
7. Tenir une **fiche de chaîne de possession** pour chaque élément.

Modèle de fiche de chaîne de possession :

Champ	Contenu
N° de preuve	INC-2026-007-P03
Description	Image disque du PC « COMPTA-02 » (SSD 256 Go), ou export CSV du journal de connexion Google
Source	Poste, numéro de série, utilisateur ; ou console et requête utilisées
Collecté par / date / heure	Nom, signature, horodatage avec fuseau (Africa/Casablanca)
Méthode et outil	Outil et version, bloqueur d'écriture le cas échéant
Empreinte SHA-256	Valeur notée à la collecte
Lieu de stockage	Armoire fermée, bureau du gérant, disque étiqueté P03
Transferts	Date, de qui à qui, motif, signatures des deux parties

Si une analyse judiciaire est probable (plainte, fraude importante), demander l'avis de l'avocat **avant** toute manipulation lourde et faire intervenir un prestataire spécialisé en investigation numérique.

7. Registre, retour d'expérience et amélioration

- Chaque incident S1 à S3 donne lieu à une **réunion de retour d'expérience** sous 10 jours ouvrés après la clôture : chronologie, ce qui a marché, ce qui a manqué, actions avec responsable et date.
- Indicateurs suivis (voir playbooks) : MTTD (délai moyen de détection), MTTA (délai de prise en charge), MTTC (délai de confinement), MTTR (délai de rétablissement), nombre de signalements par les salariés, taux de clic aux campagnes de sensibilisation.
- **Exercice sur table** au moins une fois par an (kit fourni) ; test de restauration des sauvegardes au moins une fois par trimestre.
- Révision de la politique : annuelle, ou après tout incident S1/S2.

Playbook A — Hameçonnage et compte Google Workspace compromis (BEC)

Référence	Gravité par défaut	Fonctions CSF 2.0	Propriétaire
AGS-PB-A	S3, S2 si compte compta/gérant, S1 si virement frauduleux	Detect (DE.CM, DE.AE), Respond (RS.MA, RS.AN, RS.MI), Recover (RC.RP)	Responsable de l'incident (RI)

Scénario type. Une salariée reçoit un faux courriel « document partagé » et saisit son mot de passe Google sur une fausse page. L'attaquant se connecte, crée une règle de transfert vers une adresse externe, lit les échanges avec les clients, puis envoie depuis la vraie boîte une demande de « changement de RIB » à un client B2B (fraude au changement de RIB / faux fournisseur, forme courante de BEC, *Business Email Compromise*).

1. Déclencheurs et sources de détection

Source	Signal
Salarié	Signale un courriel suspect, ou dit avoir saisi son mot de passe / validé une demande MFA inattendue
Client / fournisseur	Appelle pour vérifier un changement de RIB, ou reçoit des courriels étranges depuis notre domaine
Google Workspace — Centre d'alertes	« Suspicious login », « Leaked password », « User suspended due to suspicious activity », « Gmail potential employee spoofing », activité suspecte de règles
Google Workspace — journaux	Connexion depuis un pays ou un FAI inhabituel, connexions simultanées depuis deux pays, nouvelle règle de transfert ou filtre, nouvelle délégation, nouvelle application OAuth autorisée
Utilisateur	Messages absents de la boîte, réponses de clients à des messages jamais envoyés, alertes de sécurité Google sur le téléphone
Banque / compta	Virement contesté, demande de paiement inhabituelle

2. Triage (15 premières minutes)

- □ Ouvrir l'entrée au registre : heure du signalement, auteur, compte concerné, premier constat.
- □ Le mot de passe a-t-il été **saisi** ? Une demande MFA a-t-elle été **validée** ? Une pièce jointe a-t-elle été **ouverte** (si oui, traiter aussi le poste comme suspect) ?
- □ Vérifier dans la console d'administration les connexions récentes du compte (journal « Connexions » / *Login audit*) : IP, pays, heure, type de connexion.
- □ Vérifier dans Gmail du compte : paramètres de **transfert**, **filtres**, **délégation**, **réponse automatique**, **signature** modifiée, dossier « Envoyés » et « Corbeille ».
- □ Vérifier les **applications tierces** autorisées (OAuth) et les mots de passe d'application.
- □ Le compte a-t-il des **privilèges** (super administrateur, accès compta, banque en ligne) ?
- □ Des messages frauduleux sont-ils partis vers des clients/fournisseurs ? Un **paiement** est-il en jeu ?
- □ Combien d'autres salariés ont reçu le même courriel ? (outil d'enquête ou recherche dans les journaux selon l'édition)
- □ Fixer la gravité (S1 à S4) et appeler le gérant si S1/S2.

3. Arbre de décision

Diagramme de décision — source Mermaid (non rendu graphiquement dans ce PDF ; rendu sur GitHub ou mermaid.live, fichier `diagrams/02-playbook-phishing-bec-decision-1.mmd`). Lecture : chaque flèche « A --> B » est une étape, « -- Oui --> » une branche.

```
flowchart TD
    A["Courriel suspect signalé ou alerte Google"] --> B{"Identifiants saisis ou MFA validée ?"}
    B -- Non --> C["S4 : supprimer le courriel chez tous les destinataires, bloquer l'expéditeur / domaine, remerci
er le salarié"]
    B -- Oui / incertain --> D["Réinitialiser le mot de passe, déconnecter toutes les sessions, révoquer jetons OAu
th et mots de passe d'application"]
    D --> E{"Connexion de l'attaquant constatée dans les journaux ?"}
    E -- Non --> F["S3 : surveillance renforcée 14 jours, MFA vérifiée, sensibilisation"]
    E -- Oui --> G{"Règles de transfert, filtres, délégation ou envois frauduleux ?"}
    G -- Non --> H["S3 : supprimer les accès, revue des données consultées"]
    G -- Oui --> I{"Paiement ou changement de RIB en jeu ?"}
    I -- Non --> J["S2 : prévenir les correspondants touchés, revue des données exposées"]
    I -- Oui --> K["S1 : appel banque service fraude IMMÉDIAT, appel du client par téléphone, plainte"]
    J --> L{"Données personnelles exposées ?"}
    K --> L
    H --> L
    L -- Oui --> M["Référent données : évaluer le risque, démarche CNDP recommandée, information des personnes"]
    L -- Non --> N["Retour d'expérience"]
    M --> N
```

4. Confinement

Ordre recommandé (les actions 1 à 4 se font en quelques minutes par l'administrateur Workspace) :

1. **Réinitialiser le mot de passe** du compte depuis la console d'administration (mot de passe long, communiqué par téléphone).
2. **Déconnecter toutes les sessions** de l'utilisateur (action « Déconnexion » / réinitialisation des cookies de connexion dans la fiche utilisateur). Changer le mot de passe seul ne coupe pas toujours immédiatement toutes les sessions ouvertes.
3. **Révoquer** les jetons des applications tierces (OAuth) inconnues, les mots de passe d'application, et vérifier les méthodes de validation en deux étapes enregistrées (téléphone ou clé ajoutés par l'attaquant).
4. **Supprimer** les règles de transfert, filtres, délégations et réponses automatiques créés par l'attaquant — **après les avoir photographiés / exportés** comme preuves.
5. Si l'attaquant est encore actif ou si le compte est un compte administrateur : **suspendre** temporairement le compte.
6. **Purger le courriel d'hameçonnage** des autres boîtes (outil d'enquête si l'édition le permet, sinon demande à chaque destinataire) et bloquer l'expéditeur / le domaine / l'URL (liste de blocage Gmail).
7. Si une pièce jointe a été ouverte : isoler le poste et appliquer le volet « poste » du playbook B (analyse antivirus complète, voire réinstallation).
8. **Fraude au virement** : appeler immédiatement la banque (service fraude) pour tenter un rappel de fonds ; prévenir par **téléphone** (numéro connu, pas celui du courriel) le client ou fournisseur concerné.

5. Éradication

- □ Vérifier qu'aucun autre compte n'a été compromis (connexions depuis les mêmes IP, même campagne).
- □ Vérifier que l'attaquant n'a pas créé de compte, modifié des rôles d'administration, ajouté un domaine ou une règle de routage Gmail au niveau de l'organisation.
- □ Vérifier le partage Drive : fichiers partagés publiquement ou vers une adresse externe depuis le compte.
- □ Rechercher les messages envoyés par l'attaquant pour savoir **qui** a été contacté.
- □ Si le mot de passe était réutilisé ailleurs (banque, site web, réseaux sociaux) : le changer partout.

6. Rétablissement

- □ Réactiver le compte avec **validation en deux étapes obligatoire**, de préférence par clé de sécurité ou application (pas SMS) pour les comptes compta et gérant.

- ☐ Surveillance renforcée 14 jours : alertes de connexion, revue quotidienne des règles Gmail du compte.
- ☐ Confirmer avec les clients / fournisseurs touchés que les coordonnées bancaires réelles n'ont pas changé.
- ☐ Clôture quand : aucune activité suspecte pendant 14 jours, correspondants informés, actions de durcissement planifiées.

Mesures de durcissement (Préparation, CSF *Protect*) : MFA obligatoire pour tous ; interdiction du transfert automatique vers l'extérieur (paramètre Gmail de l'organisation) ; SPF, DKIM, DMARC en `p=quarantine` puis `p=reject` ; bannière « expéditeur externe » ; procédure **double validation par téléphone** de tout changement de RIB ; contrôle des applications tierces autorisées.

7. Preuves à collecter

Preuve	Où	Remarque
Courriel d'hameçonnage **avec en-têtes complets**	Gmail : « Afficher l'original », enregistrer en `.eml`	Ne pas le transférer comme simple pièce jointe : on perd des en-têtes
URL de la fausse page	En-tête / corps du courriel	Ne pas la visiter depuis un poste de production
Journal des connexions du compte	Console d'administration, rapports / journaux	Exporter en CSV avec la période d'intérêt (au moins 30 jours avant)
Journaux Gmail, Drive, admin, jetons OAuth	Console, page d'audit et d'enquête	Disponibilité et rétention selon l'édition
Captures des règles, filtres, délégations	Paramètres Gmail du compte	Avant suppression
Messages envoyés par l'attaquant	Dossier Envoyés, journaux	Liste des destinataires
Preuves de virement	Banque, compta	Ordre de virement, RIB frauduleux, échanges

8. Modèles de communication

8.1 Courriel / message aux salariés

Objet : [Sécurité] Courriel frauduleux en circulation — ne pas cliquer

Bonjour à toutes et à tous,

Un courriel frauduleux imitant un « document partagé » circule depuis ce matin (expéditeur : « Service Comptabilité <...> », objet : « Facture en attente »). Il conduit vers une fausse page de connexion Google.

Si vous l'avez reçu : ne cliquez pas, signalez-le avec le bouton « Signaler l'hameçonnage » puis supprimez-le. Si vous avez cliqué ou saisi votre mot de passe : **appelez immédiatement** [nom du RI] au [numéro]. Aucun reproche ne vous sera fait : plus l'alerte est rapide, plus le risque est faible.

Rappel : AgriSouss ne vous demandera jamais votre mot de passe par courriel, et tout changement de coordonnées bancaires d'un client ou fournisseur se vérifie par téléphone.

[Nom], Responsable informatique

8.2 Courriel aux clients / partenaires concernés

Objet : Information importante — courriels frauduleux envoyés au nom d'AgriSouss

Madame, Monsieur,

Le [date], un compte de messagerie d'AgriSouss SARL a été utilisé sans autorisation. Des messages frauduleux ont pu vous être envoyés, notamment une demande de modification de nos coordonnées bancaires.

Nos coordonnées bancaires n'ont pas changé. Merci de ne donner suite à aucune demande de ce type et, en cas de doute, de nous appeler au [numéro fixe officiel].

Nous avons sécurisé le compte concerné et renforcé nos contrôles. Si vous avez effectué un paiement sur la base d'un de ces messages, contactez votre banque sans attendre et prévenez-nous.

Nous vous prions de nous excuser pour ce désagrément.

[Nom], Gérant — AgriSouss SARL — [téléphone]

9. Check-list post-incident

- □ Chronologie complète : premier courriel, clic, première connexion de l'attaquant, détection, confinement.
- □ Cause racine : absence de MFA ? MFA par SMS contournée ? MFA « fatigue » ? Page relais (*adversary-in-the-middle*) ?
- □ Données consultées ou exfiltrées identifiées ; décision CNDP / information des personnes documentée.
- □ Plainte déposée si fraude ; suivi bancaire.
- □ Mesures de durcissement planifiées (MFA forte, DMARC, blocage du transfert externe, procédure RIB).
- □ Sensibilisation ciblée sous 2 semaines (sans stigmatiser la personne).
- □ Registre mis à jour ; indicateurs calculés.

10. Indicateurs (KPI)

Indicateur	Définition	Cible
MTTD	Délai entre la première connexion de l'attaquant et la détection	< 24 h (objectif : alerte Google traitée < 1 h)
MTTA	Délai entre le signalement et la prise en charge par le RI	< 30 min en heures ouvrées
MTTC	Délai entre la détection et la coupure de toutes les sessions de l'attaquant	< 1 h
MTTR	Délai entre la détection et le retour à la normale (compte sécurisé, correspondants prévenus)	< 2 jours ouvrés
Taux de signalement	% de destinataires qui signalent un courriel d'hameçonnage (réel ou simulé)	> 50 %
Taux de clic	% de destinataires qui cliquent lors des campagnes de sensibilisation	< 10 % et en baisse

Playbook B — Rançongiciel sur un poste ou sur le partage de fichiers (NAS)

Référence	Gravité par défaut	Fonctions CSF 2.0	Propriétaire
AGS-PB-B	S2 (un poste isolé), S1 (NAS, plusieurs postes, sauvegardes touchées)	Detect, Respond (RS.MA, RS.AN, RS.MI, RS.CO), Recover (RC.RP, RC.CO)	Responsable de l'incident (RI)

Scénario type. Un poste du service commercial ouvre une pièce jointe piégée ou un accès distant mal protégé est exploité. Des fichiers sont renommés avec une nouvelle extension, une note de rançon apparaît, et le chiffrement atteint le dossier partagé du NAS monté en lecteur réseau. Les rançongiciels actuels pratiquent souvent la **double extorsion** : vol de données avant chiffrement, puis menace de publication.

1. Déclencheurs et sources de détection

Source	Signal
Utilisateur	Fichiers illisibles, extension inconnue, fond d'écran changé, fichier `README` / `HOW_TO_DECRYPT` dans les dossiers
Microsoft Defender	Alerte rançongiciel, accès contrôlé aux dossiers déclenché, outil de piratage détecté, antivirus désactivé
NAS	Pic d'écritures / renommages, alerte de l'antivirus du NAS, quotas saturés, instantanés supprimés
Sauvegarde	Échec de la tâche nocturne, taille de sauvegarde anormale
Réseau	Poste qui scanne les autres postes, trafic sortant important la nuit
Externe	Message de l'attaquant, mention de l'entreprise sur un site de fuite, alerte d'un partenaire ou du maCERT

2. Triage (premières minutes — agir vite)

- □ **Isoler immédiatement** chaque poste touché : débrancher le câble réseau, couper le Wi-Fi. **Ne pas éteindre** (la mémoire peut contenir des clés ou des traces utiles), sauf cas décrit ci-dessous.
- □ Si le NAS est touché ou risque de l'être : **déconnecter le NAS du réseau** (câble) et **débrancher le disque de sauvegarde USB** s'il est branché.
- □ Photographier la note de rançon et un exemple de fichier chiffré (nom, extension).
- □ Recenser : quels postes, quels partages, quels comptes utilisateurs ; depuis quand ?
- □ Vérifier l'état des **sauvegardes** : copie hors site intacte ? date de la dernière copie saine ? sauvegardes chiffrées ou supprimées ?
- □ Classer la gravité ; S1 : appeler le gérant et le prestataire, activer le groupe de crise hors bande.
- □ Interdire aux salariés de rallumer, rebrancher ou « tester » des postes.

Éteindre ou non ? La règle par défaut est d'isoler sans éteindre. Si le chiffrement est visiblement en cours et que l'isolement réseau ne l'arrête pas (chiffrement local qui continue), ou s'il est impossible de débrancher, on peut **mettre en veille prolongée** (hibernation : le contenu de la mémoire est écrit dans `hiberfil.sys`, exploitable ensuite par un analyste) ou, en dernier recours, couper l'alimentation (la mémoire vive est alors perdue, mais on sauve des fichiers). Noter la décision et l'heure.

3. Arbre de décision

Diagramme de décision — source Mermaid (non rendu graphiquement dans ce PDF ; rendu sur GitHub ou mermaid.live, fichier `diagrams/03-playbook-ransomware-decision-1.mmd`). Lecture : chaque flèche « A --> B » est une étape, « -- Oui --> » une branche.

```
flowchart TD
    A["Fichiers chiffrés ou note de rançon"] --> B["Isoler le ou les postes du réseau, ne pas éteindre"]
    B --> C{"Le NAS ou plusieurs postes sont touchés ?"}
    C -- Non --> D["S2 : un poste. Préserver les preuves, vérifier les comptes utilisés"]
    C -- Oui --> E["S1 : couper le NAS du réseau, débrancher la sauvegarde USB, cellule de crise"]
    D --> F{"Propagation ou compte administrateur utilisé ?"}
    F -- Oui --> E
    F -- Non --> G["Réinstaller le poste, restaurer ses données"]
    E --> H{"Sauvegarde saine et hors ligne disponible ?"}
    H -- Oui --> I["Éradiquer puis restaurer depuis la sauvegarde"]
    H -- Non --> J["Identifier la souche, chercher un déchiffreur sur No More Ransom, avis prestataire et avocat"]
    J --> K{"Déchiffreur public fiable ?"}
    K -- Oui --> I
    K -- Non --> L["Reconstruction et ressaisie ; refus de payer par défaut, décision écrite du gérant si l'option
est étudiée"]
    I --> M{"Indices de vol de données ?"}
    L --> M
    G --> M
    M -- Oui --> N["Référent données : CNDP recommandé, information des personnes, plainte"]
    M -- Non --> O["Plainte recommandée, signalement maCERT, retour d'expérience"]
    N --> O
```

4. Confinement

1. **Isoler** les postes touchés (fait au triage) ; si nécessaire isoler tout le réseau du bureau d'Internet (couper le lien de la box) le temps de comprendre.
2. **Couper le NAS** du réseau et **protéger les sauvegardes** : débrancher les disques USB, suspendre les tâches de synchronisation (un client de synchronisation cloud peut propager les fichiers chiffrés vers le cloud).
3. **Désactiver les comptes** utilisés par l'attaque (compte de l'utilisateur, compte administrateur local ou du NAS) et changer les mots de passe **depuis un poste sain**.
4. Bloquer les accès distants (bureau à distance exposé, VPN, logiciel de télémaintenance) jusqu'à vérification.
5. Garder une **liste à jour** des postes : isolé / sain vérifié / à réinstaller.
6. Ne pas entrer en contact avec l'attaquant sans décision du directeur de crise et avis de l'avocat.

5. Éradication

- □ **Identifier la souche** à partir de la note et de l'extension (service ID Ransomware, ou projet No More Ransom). Attention : téléverser une note ou un fichier sur un service externe peut révéler des informations ; utiliser un échantillon sans donnée sensible.
- □ **Trouver le point d'entrée** : pièce jointe, macro, accès distant exposé, mot de passe faible ou réutilisé, logiciel non à jour. Sans cause racine, la réinfection est probable.
- □ Rechercher la **persistance** et les autres postes touchés (comptes créés, tâches planifiées, outils de télémaintenance installés par l'attaquant) avec l'aide du prestataire.
- □ **Réinstaller** les postes compromis à partir d'une image propre (ne pas se contenter de « nettoyer »). Mettre à jour système et logiciels avant reconnexion.
- □ Réinitialiser **tous** les mots de passe des comptes qui ont pu être exposés (postes, NAS, Google Workspace si saisis sur un poste touché, banque en ligne).

6. Rétablissement

- □ Vérifier la sauvegarde **avant** restauration : date antérieure à la compromission, absence de fichiers chiffrés, analyse antivirus.

- ☐ Restaurer par **priorité métier** : 1) facturation / compta, 2) commandes et logistique, 3) dossiers commerciaux, 4) archives.
- ☐ Reconnecter les postes un par un, uniquement ceux marqués « sain vérifié ».
- ☐ Surveillance renforcée 30 jours (alertes Defender, connexions au NAS, sorties réseau).
- ☐ Recalculer la perte de données réelle (RPO) et le temps d'indisponibilité (RTO atteint).

Préparation (CSF *Protect* / *Recover*) : sauvegarde **3-2-1-1-0** (3 copies, 2 supports, 1 hors site, 1 hors ligne ou immuable, 0 erreur au test de restauration) ; test de restauration trimestriel ; instantanés du NAS protégés ; comptes standards sans droits administrateur ; accès contrôlé aux dossiers de Defender ; macros Office bloquées pour les fichiers d'Internet ; pas de bureau à distance exposé sur Internet.

7. Preuves à collecter (ordre de volatilité)

Ordre	Preuve	Méthode	Remarque
1	Mémoire vive du poste (si encore allumé et compétence disponible)	Outil de capture mémoire par le prestataire	Peut contenir des clés ou des traces de l'outil ; à faire avant tout redémarrage
2	Connexions réseau et processus actifs	Captures d'écran ou export par le prestataire	Très volatil
3	Note de rançon, exemples de fichiers chiffrés	Copie + photo, SHA-256	Utile pour identifier la souche et pour la plainte
4	Journaux Windows (Sécurité, Système, Defender)	Export des journaux par le prestataire	Avant réinstallation
5	Image disque du poste « patient zéro »	Copie bit à bit par un prestataire, SHA-256	Si plainte ou assurance ; sinon conserver au moins le disque
6	Journaux du NAS, de la box / pare-feu, de l'antivirus	Export depuis les interfaces	Rétention souvent courte
7	Messages de l'attaquant, adresses de contact, portefeuille de crypto-actifs indiqué	Captures, copies	Ne pas répondre

8. Modèles de communication

8.1 Message aux salariés (SMS / WhatsApp, puis oral)

> **[URGENT — Sécurité informatique]** Un virus de type rançongiciel touche une partie de nos ordinateurs. Jusqu'à nouvel ordre :
> 1. Ne rallumez pas, ne rebranchez pas et ne « testez » pas les ordinateurs marqués d'une étiquette rouge.
> 2. N'utilisez pas le lecteur partagé (NAS).
> 3. Ne parlez pas de l'incident à l'extérieur (clients, réseaux sociaux) : la communication est assurée par la direction.
> 4. Signalez tout comportement anormal à [nom du RI] au [numéro].
>
> Point de situation à [heure]. Merci de votre aide. — [Gérant]

8.2 Courriel aux clients (si impact sur les commandes ou suspicion de vol de données)

> **Objet : Incident informatique chez AgriSouss — information à nos clients**
>
> Madame, Monsieur,
>
> AgriSouss SARL a subi le [date] une attaque informatique qui a rendu indisponibles une partie de nos systèmes internes. Nous avons immédiatement isolé les équipements touchés et engagé un prestataire spécialisé.
>
> [Choisir selon l'état de l'analyse]
>
> — À ce stade, nos investigations n'ont pas mis en évidence d'accès à vos données. Elles se poursuivent et nous vous tiendrons informés.
>
> — Nos investigations indiquent que des données vous concernant ([nature : nom, coordonnées, factures]) ont pu être copiées. Soyez vigilants face aux courriels, appels ou demandes de paiement se réclamant d'AgriSouss ; nos coordonnées bancaires n'ont pas changé.
>
> Conséquences pour vos commandes : [délais, contact pour les commandes urgentes].
>
> Une plainte a été déposée. Pour toute question : [contact dédié, téléphone].
>
> [Nom], Gérant — AgriSouss SARL

9. Check-list post-incident

- □ Chronologie : intrusion initiale, mouvement latéral, chiffrement, détection, isolement, restauration.
- □ Cause racine et vecteur d'entrée documentés et corrigés.
- □ Données exfiltrées ? (indices de transfert, mention sur un site de fuite) ; décision CNDP / information des personnes documentée.
- □ Plainte déposée, signalement maCERT effectué (volontaire), assureur prévenu si contrat.
- □ Sauvegardes : ce qui a fonctionné, ce qui a manqué ; test de restauration ajouté au calendrier.
- □ Coût de l'incident estimé (temps, prestataire, perte de chiffre d'affaires).
- □ Plan d'actions avec responsables et dates ; prochain exercice sur table planifié.

10. Indicateurs (KPI)

Indicateur	Définition	Cible
MTTD	Délai entre le début du chiffrement (ou l'intrusion, si connue) et la détection	< 1 h pour le chiffrement
MTTC	Délai entre la détection et l'isolement de tous les équipements touchés	< 30 min
MTTR	Délai entre la détection et la reprise des activités critiques (facturation, commandes)	< 48 h (RTO cible)
RPO atteint	Âge de la dernière sauvegarde saine restaurée	≤ 24 h
Taux de succès des tests de restauration	Tests trimestriels réussis / tests planifiés	100 %
Postes réinstallés à temps	% de postes compromis réinstallés avant reconnexion	100 %

Playbook C — Compromission du site e-commerce (défiguration, web shell, fuite de données clients)

Référence	Gravité par défaut	Fonctions CSF 2.0	Propriétaire
AGS-PB-C	S2 (défiguration, web shell), S1 (fuite de données clients ou atteinte au paiement)	Detect, Respond (RS.MA, RS.AN, RS.MI, RS.CO), Recover (RC.RP, RC.CO)	RI, avec l'hébergeur

Contexte. La boutique est une application PHP avec une base MariaDB, chez un hébergeur externe. AgriSouss n'a pas d'accès complet au serveur : en hébergement mutualisé, les journaux, instantanés et restaurations passent par le panneau d'hébergement ou le support. Le paiement par carte est délégué à une **page de paiement hébergée** par le prestataire de paiement (type CMI) : le site ne doit **jamais** stocker de numéro de carte. Si ce n'est pas le cas, l'incident devient S1 et le prestataire de paiement doit être prévenu.

Variantes. (1) Défiguration : page d'accueil remplacée. (2) Web shell : script PHP déposé permettant à l'attaquant de commander le serveur, souvent via un formulaire d'envoi de fichiers, un module non à jour ou un mot de passe d'administration volé. (3) Fuite de données : base clients extraite (injection SQL, sauvegarde laissée accessible, identifiants de base volés). (4) Script malveillant injecté dans les pages (redirection, faux formulaire de paiement).

1. Déclencheurs et sources de détection

Source	Signal
Client / visiteur	Page modifiée, redirection vers un autre site, alerte du navigateur « site dangereux », faux formulaire de paiement
Hébergeur	Notification d'abus, suspension, alerte de l'antivirus du serveur, consommation anormale
Supervision	Supervision de disponibilité ou de contenu (changement de la page d'accueil), alerte de contrôle d'intégrité des fichiers
Google Search Console	Alerte « site piraté » ou « problèmes de sécurité »
Journaux du serveur web	Requêtes POST vers des fichiers PHP inconnus, nombreuses erreurs 500, requêtes avec motifs d'injection SQL, connexions à l'administration depuis des IP inconnues
Externe	Base de données mise en vente ou publiée, clients qui reçoivent des hameçonnages très ciblés, signalement d'un chercheur ou du maCERT
Prestataire de paiement	Signalement de fraudes à la carte dont le point commun est la boutique

2. Triage

- □ Ouvrir l'entrée au registre ; capturer l'écran du site (date/heure visibles) et noter les URL concernées.
- □ Quelle variante ? Défiguration, fichier suspect, redirection/script injecté, fuite de données, combinaison ?
- □ Le **paiement** est-il concerné (page de paiement modifiée, formulaire de carte ajouté) ?
- □ La **base clients** est-elle accessible à l'attaquant (identifiants de base dans un fichier de configuration lisible par un web shell = à considérer comme exposée) ?
- □ Appeler l'**hébergeur** : demander instantané/sauvegarde du compte **dans son état actuel**, export des journaux d'accès et d'erreurs, état de leurs propres alertes.
- □ Fixer la gravité ; S1 si données personnelles ou paiement probables.

3. Arbre de décision

Diagramme de décision — source Mermaid (non rendu graphiquement dans ce PDF ; rendu sur GitHub ou mermaid.live, fichier `diagrams/04-playbook-compromission-site-web-decision-1.mmd`). Lecture : chaque flèche « A --> B » est une étape, « -- Oui --> » une branche.

```
flowchart TD
    A["Site anormal, alerte hébergeur ou signalement"] --> B["Capturer l'état, demander à l'hébergeur un instantané
 et les journaux"]
    B --> C["Mettre le site en maintenance ou le faire suspendre"]
    C --> D{"Script ou fichier PHP inconnu côté serveur ?"}
    D -- Non --> E{"Seulement contenu modifié via l'administration ?"}
    E -- Oui --> F["S2 : compte admin compromis, changer tous les accès, restaurer le contenu"]
    E -- Non --> G["Analyse approfondie avec l'hébergeur"]
    D -- Oui --> H["S2 au minimum : web shell présumé, accès serveur et base à considérer comme exposés"]
    H --> I{"Données clients ou paiement concernés ?"}
    G --> I
    F --> I
    I -- Oui --> J["S1 : prévenir le prestataire de paiement, référent données, avocat, CNDP recommandé"]
    I -- Non / inconnu --> K["Hypothèse prudente tant que l'analyse n'exclut pas l'accès"]
    J --> L["Reconstruire depuis code et sauvegarde sains, corriger la faille, changer tous les secrets"]
    K --> L
    L --> M["Remise en ligne contrôlée, surveillance 30 jours, retour d'expérience"]
```

4. Confinement

1. **Préserver avant de nettoyer** : demander à l'hébergeur un instantané du compte (fichiers + base) et l'export des journaux. Supprimer un web shell sans copie détruit la preuve et la compréhension de l'attaque.
2. **Mettre le site en maintenance** (page statique) ou demander une suspension temporaire, surtout s'il distribue du code malveillant ou un faux formulaire de paiement.
3. **Changer tous les accès** depuis un poste sain : panneau d'hébergement, FTP/SFTP, SSH, comptes administrateurs de la boutique, utilisateur MariaDB (mettre à jour le fichier de configuration), clés d'API (paiement, transporteurs, courriel transactionnel).
4. Supprimer les **comptes administrateurs inconnus** de la boutique et de la base après capture.
5. Bloquer temporairement l'accès à l'administration de la boutique par adresse IP ou authentification supplémentaire si l'hébergeur le permet.
6. Prévenir le **prestataire de paiement** si la page de paiement ou les redirections vers elle ont pu être modifiées.

5. Éradication

- □ Comparer les fichiers du serveur avec une **source de référence** (dépôt Git, archive de livraison du développeur) : fichiers ajoutés, modifiés, dates récentes, PHP dans les dossiers d'images ou d'envoi de fichiers.
- □ Rechercher dans la base : comptes administrateurs ajoutés, contenus modifiés, scripts insérés dans les pages ou paramètres.
- □ Analyser les journaux pour trouver le **vecteur** : requête d'exploitation, connexion admin réussie depuis une IP inconnue, envoi de fichier suspect.
- □ Corriger la **cause racine** : mise à jour du code / des modules, requêtes préparées contre l'injection SQL, contrôle des types de fichiers envoyés et interdiction d'exécuter du PHP dans le dossier d'envoi, mots de passe forts + MFA sur l'administration.
- □ Ne **pas** se contenter de supprimer le fichier malveillant visible : un attaquant laisse souvent plusieurs accès.

6. Rétablissement

- □ Reconstruire le site à partir du **code de référence** corrigé et d'une **sauvegarde de base saine** (antérieure à l'intrusion), en réintégrant les commandes légitimes passées depuis (à partir des exports du prestataire de paiement ou de la compta).

- ☐ Vérifier : pas de fichier inconnu, page de paiement conforme, en-têtes de sécurité, TLS valide.
- ☐ Remettre en ligne ; demander le réexamen dans Google Search Console si le site a été signalé.
- ☐ Surveillance renforcée 30 jours : intégrité des fichiers, connexions admin, erreurs, disponibilité.

Préparation (CSF *Protect*) : code sous Git ; sauvegarde quotidienne fichiers + base conservée hors de l'hébergeur ; mises à jour mensuelles ; MFA sur l'administration ; compte de base de données à privilèges minimaux ; pas de données de carte sur le site ; supervision de disponibilité et de contenu ; pare-feu applicatif (WAF) si disponible ; contrat d'hébergement qui précise rétention des journaux et délai d'intervention.

7. Preuves à collecter

Preuve	Où	Remarque
Captures du site (page défigurée, redirection)	Navigateur d'un poste sain	Date/heure visibles, URL
Instantané complet fichiers + base à l'état compromis	Hébergeur	SHA-256 de l'archive reçue
Journaux d'accès et d'erreurs du serveur web	Hébergeur / panneau	Période : au moins 30 à 90 jours avant détection si disponible
Journaux FTP/SFTP/SSH, panneau d'hébergement	Hébergeur	Connexions et envois de fichiers
Fichiers suspects (web shell)	Copie dans l'archive, **pas** exécutés	Conserver chemin, dates, propriétaire
Liste des comptes admin et des modifications en base	Export SQL	Avant suppression
Échanges avec l'hébergeur et le prestataire de paiement	Messagerie	Numéros de ticket
Preuve de publication de la base (si fuite)	Capture de l'annonce	Ne pas télécharger ni acheter la base

8. Modèles de communication

8.1 Message aux salariés

> **Objet : [Sécurité] Boutique en ligne temporairement en maintenance**
>
> Bonjour,
>
> Notre boutique en ligne est mise en maintenance suite à un incident de sécurité en cours d'analyse avec notre hébergeur. Les commandes peuvent être prises par téléphone au [numéro] / par courriel à [adresse].
>
> Merci de ne pas commenter l'incident auprès des clients ou sur les réseaux sociaux ; orientez toute question vers [nom du gérant]. Une note sera communiquée aux clients par la direction.
>
> [Nom], Responsable informatique

8.2 Courriel aux clients (en cas de fuite de données avérée ou probable)

Objet : Information sur un incident de sécurité concernant votre compte client AgriSouss

Madame, Monsieur,

Le [date], nous avons détecté un accès non autorisé à notre boutique en ligne. Nous avons immédiatement mis le site en maintenance, sécurisé nos systèmes avec notre hébergeur et engagé une analyse.

Données concernées : [nom, adresse électronique, adresse de livraison, téléphone, historique de commandes, mot de passe stocké sous forme hachée]. **Données non concernées :** vos données de carte bancaire, qui sont saisies uniquement sur la page sécurisée de notre prestataire de paiement et ne sont pas stockées par AgriSouss. [Ne laisser cette phrase que si elle est vérifiée.]

Ce que nous vous recommandons :

- changer votre mot de passe sur notre site à sa réouverture, et sur tout autre site où vous utilisez le même ;
- vous méfier des courriels, SMS ou appels se présentant comme AgriSouss et demandant un paiement ou des informations ;
- nous signaler tout message suspect à [adresse].

Nous avons [porté plainte / informé la CNDP — selon les démarches effectives]. Nous regrettons sincèrement cet incident. Pour toute question : [contact dédié, téléphone].

[Nom], Gérant — AgriSouss SARL

9. Check-list post-incident

- □ Chronologie : vulnérabilité exploitée, date de l'intrusion, actions de l'attaquant, détection, remise en ligne.
- □ Faille corrigée et vérifiée ; tous les secrets changés.
- □ Périmètre de la fuite établi (tables, nombre de personnes, champs) ; décision CNDP, information des clients, RGPD si clients UE : documentées avec avis juridique.
- □ Prestataire de paiement informé si concerné ; plainte déposée si fuite ou fraude.
- □ Contrat d'hébergement revu (journaux, sauvegardes, délai d'intervention).
- □ Plan d'actions : mises à jour, revue de code, supervision d'intégrité, audit externe passif (voir projet RSSI Audit).

10. Indicateurs (KPI)

Indicateur	Définition	Cible
MTTD	Délai entre l'intrusion (déterminée a posteriori dans les journaux) et la détection	< 24 h (défiguration : < 1 h avec supervision de contenu)
MTTC	Délai entre la détection et la mise en maintenance + changement des accès	< 2 h
MTTR	Délai entre la détection et la remise en ligne sécurisée	< 3 jours ouvrés
Délai d'information des clients	Délai entre la confirmation d'une fuite et l'information des personnes	Le plus court possible, objectif < 72 h
Délai de mise à jour	Délai moyen entre la publication d'un correctif de sécurité et son application	< 14 jours (< 72 h si exploité activement)

Kit d'exercice sur table — « Récolte chiffrée » (rançongiciel)

> **EXERCICE SIMULÉ.** Tout ce chapitre décrit un exercice de discussion. Aucun système n'est touché, aucun outil n'est lancé. Les noms, chiffres et événements sont fictifs.

1. Fiche d'identité de l'exercice

Élément	Valeur
Format	Exercice sur table (discussion), salle de réunion, 2 h 30 dont 30 min de débriefing
Participants	Gérant (directeur de crise), RAF (référent données), informaticien (RI), un commercial, le chef de station logistique ; prestataire IT invité (en visio)
Animation	1 animateur (facilitateur) + 1 observateur preneur de notes
Playbook testé	AGS-PB-B Rançongiciel ; politique AGS-POL-IR-01
Objectifs	O1 : isoler correctement et vite. O2 : activer la cellule de crise et le canal hors bande. O3 : vérifier que les sauvegardes permettent de repartir (RPO/RTO). O4 : prendre et justifier la décision sur la rançon. O5 : produire des communications internes et clients exactes. O6 : identifier les démarches légales (plainte, CNDP, maCERT).
Hors périmètre	Investigation technique détaillée, négociation réelle

2. Guide de l'animateur

Avant (J-14 à J-1)

- Valider la date avec le gérant ; bloquer 2 h 30 sans téléphone (sauf pour les injects).
- Imprimer : playbook B, fiche réflexe B, politique (section rôles et autorités), annuaire de crise, cartes d'injects (une par inject, à distribuer au fil de l'eau).
- Préparer un tableau blanc avec une **ligne de temps** et trois colonnes : Décisions / Actions / Questions ouvertes.
- Ne pas communiquer le scénario aux participants.

Pendant

- Rappeler les règles en ouverture (5 min) : environnement sans jugement, on joue « comme si », pas de bonne réponse unique, on dit « je ne sais pas » plutôt que d'inventer, le temps de l'exercice est accéléré.
- Lire chaque inject à voix haute, distribuer la carte, laisser **10 à 20 min** de discussion, puis poser les questions prévues.
- Ne pas donner la solution ; relancer avec « Qui fait quoi ? Comment le savez-vous ? Où est-ce écrit ? ».
- Si le groupe bloque plus de 5 min, donner un indice (« Que dit la fiche réflexe ? »).
- L'observateur note les **heures fictives** des décisions et les écarts par rapport au playbook.

Après

- Débriefing à chaud de 30 min (ce qui a bien marché / ce qui a manqué / 3 actions prioritaires).
- Rapport post-exercice (RETEX) envoyé sous 10 jours ouvrés ; plan d'actions suivi en réunion mensuelle.

3. Scénario et injects

Situation de départ (lue par l'animateur). Mardi, 8 h 40, pleine saison d'export des agrumes. Le bureau tourne à plein ; trois camions doivent partir à 14 h avec des documents d'export et des factures.

N°	Heure fictive	Inject (ce qui est annoncé aux participants)	Ce qu'on attend	Questions à poser
1	08:40	Salma (commerciale) appelle : « Mes fichiers Excel ne s'ouvrent plus, ils finissent tous par `.agrlck`, et il y a un fichier `LISEZ-MOI.txt` sur mon bureau. »	Reconnaître un rançongiciel probable ; isoler le poste sans l'éteindre ; ouvrir le registre	Que dit-on à Salma, mot pour mot ? Qui décide ? Éteint-on le PC ?
2	09:05	Le chef de station signale que le dossier partagé « EXPORT » sur le NAS contient aussi des fichiers `.agrlck`. Deux autres postes affichent la note.	Passer en S1 ; couper le NAS ; débrancher le disque USB de sauvegarde ; appeler le gérant ; activer le groupe de crise hors bande	Quel niveau de gravité ? Qui appelle qui, et par quel canal ? Que fait-on du disque USB branché sur le NAS ?
3	10:00	L'informaticien constate que le disque USB de la nuit est **lui aussi chiffré** (il était branché en permanence). La dernière copie hors site date d'il y a **6 jours**. Le prestataire IT peut venir à 15 h.	Évaluer la perte (6 jours) ; prioriser la restauration ; organiser un mode dégradé (documents d'export à la main, depuis les courriels Gmail)	Qu'est-ce qui est vraiment critique aujourd'hui ? Comment faire partir les camions à 14 h ? Qu'avions-nous promis comme RPO ?
4	11:30	Un courriel arrive sur l'adresse de contact : l'attaquant réclame l'équivalent de **8 000 USD en crypto-actifs** sous 72 h, et affirme avoir **copié la base clients et les factures**, avec une capture d'écran de dossiers internes en preuve.	Ne pas répondre à chaud ; conserver le message ; prendre en compte la double extorsion ; appeler l'avocat ; préparer la décision sur la rançon	Paie-t-on ? Qui décide, sur quels critères ? Quelles conséquences juridiques et pratiques ? Le vol de données change-t-il nos obligations ?
5	13:00	Un client B2B important, à Agadir, appelle : il a entendu « qu'AgriSouss a été piraté » et demande si ses données et ses commandes sont en danger. Un salarié a publié « journée galère, tout est planté » sur un réseau social.	Message client factuel et prudent ; rappel interne sur la communication ; porte-parole unique	Que lui répond-on exactement ? Que fait-on de la publication du salarié ? Faut-il prévenir les autres clients maintenant ?
6	16:30	Le prestataire identifie le vecteur probable : un **accès bureau à distance exposé** sur un PC avec un mot de passe faible, activé l'an dernier pour du télétravail. Il propose de réinstaller les trois postes et de restaurer le NAS depuis la copie hors site.	Valider le plan d'éradication et de restauration ; changer les mots de passe ; fermer l'accès distant ; plainte ; démarches CNDP et maCERT ; planifier le retour d'expérience	Qu'est-ce qui garantit qu'on ne sera pas réinfectés ? Qui dépose plainte et avec quelles preuves ? Que dit-on à la CNDP, et faut-il la contacter ? Quand clôture-t-on ?

Inject de réserve (si le groupe va vite) : 18 h — le gérant reçoit un SMS de « la banque » demandant de confirmer un virement urgent. Test : hameçonnage opportuniste pendant la crise, vérification hors bande.

4. Questions transverses aux participants

1. Où se trouve la liste des numéros d'urgence si les PC et le NAS sont inaccessibles ?
2. Qui a l'autorité pour couper le NAS ou Internet pendant les heures de travail ?
3. Comment savons-nous que la copie hors site n'est pas elle aussi compromise ?
4. Combien de jours de travail pouvons-nous perdre sans conséquence grave ? Le savions-nous avant aujourd'hui ?
5. Quels documents pouvons-nous reconstituer depuis Gmail / Drive, et lesquels sont perdus ?
6. Qu'est-ce qui est obligatoire pour nous vis-à-vis de la CNDP, de la DGSSI / maCERT et de la police, et qu'est-ce qui est seulement recommandé ?
7. Quelle est notre position sur le paiement d'une rançon, et est-elle écrite quelque part ?
8. Qui parle aux clients, à la presse, aux salariés ?
9. Quelles preuves faut-il garder pour la plainte et comment les conserve-t-on ?
10. Qu'aurions-nous dû avoir en place avant pour que cet incident soit mineur ?

5. Grille d'évaluation

Notation par l'observateur : 0 = non réalisé, 1 = partiel ou tardif, 2 = conforme au playbook.

N°	Critère	Objectif lié	Attendu	Note (0-2)	Commentaire
E1	Isolement réseau du premier poste sans extinction	O1	< 10 min fictives après l'inject 1		
E2	Coupure du NAS et protection de la sauvegarde	O1	Dès l'inject 2		
E3	Classement S1 et escalade au gérant	O2	Inject 2		
E4	Utilisation d'un canal de crise hors bande	O2	Inject 2		
E5	Registre d'incident tenu (heures, décisions)	O2	Tout l'exercice		
E6	Évaluation RPO/RTO et priorités métier	O3	Inject 3		
E7	Mode dégradé pour la continuité (camions de 14 h)	O3	Inject 3		
E8	Décision rançon argumentée, avis juridique, refus par défaut	O4	Inject 4		
E9	Prise en compte de la double extorsion (données)	O4/O6	Inject 4		
E10	Message client exact, sans promesse non vérifiée	O5	Inject 5		
E11	Message interne et gestion de la publication du salarié	O5	Inject 5		
E12	Préservation des preuves et chaîne de possession	O6	Injects 1 à 6		
E13	Démarches : plainte, CNDP (recommandé), maCERT (volontaire)	O6	Inject 6		
E14	Cause racine traitée avant reconnexion	O1/O3	Inject 6		
	Total			**/28**	

Lecture : 24-28 dispositif mature ; 16-23 base solide avec écarts ; 8-15 dispositif à renforcer ; < 8 dispositif à construire.

6. Exemple de rapport post-exercice (RETEX)

> **EXERCICE SIMULÉ — RAPPORT D'EXEMPLE.** Ce rapport illustre le format attendu. Il ne décrit **aucun** incident réel ni aucun exercice qui aurait été mené dans une entreprise réelle. Les résultats sont inventés pour l'illustration.

Élément	Valeur
Exercice	« Récolte chiffrée » — rançongiciel, format sur table
Date (fictive)	Jeudi 2026-11-12, 9 h 00 - 11 h 30
Participants	Gérant, RAF, informaticien, commerciale, chef de station ; prestataire IT en visio
Animateur / observateur	Animateur externe (fictif) / observateur : stagiaire administratif
Score	**17 / 28** — base solide avec écarts importants

Synthèse. L'équipe a réagi vite au premier signalement et a correctement isolé le poste sans l'éteindre. La coupure du NAS a été décidée rapidement, mais personne n'a pensé au disque USB de sauvegarde branché en permanence, ce qui, dans le scénario, a fait perdre 6 jours de données. La décision de ne pas payer a été prise et justifiée, mais la position n'était écrite nulle part avant l'exercice. La communication client a été improvisée et contenait au départ une promesse non vérifiée (« aucune donnée n'a été volée »).

Chronologie fictive des décisions

Heure fictive	Décision / action	Écart
08:46	Poste de Salma débranché du réseau, laissé allumé	Conforme
09:12	Classement S1, appel du gérant par téléphone	Conforme
09:20	NAS débranché du réseau	Conforme ; disque USB oublié (E2 = 1)
09:35	Groupe WhatsApp de crise improvisé	Groupe non créé à l'avance, numéro du prestataire introuvable (E4 = 1)
10:40	Mode dégradé : documents d'export refaits depuis Gmail	Bonne idée, venue du chef de station
11:50	Refus de payer, appel de l'avocat	Avocat non référencé à l'avance
13:10	Réponse au client : « aucune donnée volée »	Promesse non vérifiée, corrigée par le RAF (E10 = 1)
16:45	Plan de réinstallation validé ; plainte décidée	CNDP et maCERT évoqués seulement sur relance de l'animateur (E13 = 1)

Notes par critère : E1 2, E2 1, E3 2, E4 1, E5 0 (registre non tenu, notes éparses), E6 1, E7 2, E8 2, E9 1, E10 1, E11 1, E12 0, E13 1, E14 2 → **17/28**.

Points forts

- Réflexe d'isolement sans extinction acquis.
- Bonne idée de mode dégradé à partir de Gmail pour les documents d'export.
- Refus de payer argumenté (aucune garantie, financement du crime, double extorsion qui reste possible même après paiement).

Axes d'amélioration

1. Sauvegarde : le disque USB toujours branché n'est pas une copie hors ligne.
2. Pas d'annuaire de crise papier ni de groupe de crise créé à l'avance.
3. Preuves : personne n'a parlé de photographier la note, de conserver le courriel de l'attaquant ni de la chaîne de possession (E12 = 0).
4. Communication : pas de modèle préparé, promesse non vérifiée.
5. Obligations légales mal connues (confusion entre CNDP obligatoire et recommandée, maCERT inconnu de la direction).

Plan d'actions

N°	Action	Responsable	Échéance	Priorité
A1	Mettre en place une rotation de 2 disques USB, dont un toujours débranché et emporté hors site ; ou une sauvegarde cloud immuable	Informaticien	2026-12-15	Haute
A2	Test de restauration du NAS chronométré, puis trimestriel	Informaticien + prestataire	2026-12-31	Haute
A3	Créer le groupe de crise et l'annuaire papier (coffre + domicile du gérant)	RAF	2026-11-30	Haute
A4	Fermer tout accès bureau à distance exposé ; recenser les accès distants	Prestataire	2026-11-30	Haute
A5	Écrire la position « rançon » dans la politique, validée par le gérant et l'avocat	Gérant	2026-12-31	Moyenne
A6	Imprimer les fiches réflexes et les afficher ; former les salariés en 30 min	Informaticien	2027-01-15	Moyenne
A7	Préparer les modèles de communication clients validés par l'avocat	RAF	2027-01-31	Moyenne
A8	Rejouer un exercice (scénario BEC)	Informaticien	2027-05	Basse

Fiches réflexes (à imprimer et afficher)

Une page par playbook. À afficher près des postes et à glisser dans l'annuaire de crise papier. Les numéros sont à compléter.

FICHE RÉFLEXE A — Courriel piégé / compte Google piraté

Numéro d'alerte : RI [_____] — suppléant [_____] — gérant [_____]

Vous avez cliqué, saisi votre mot de passe ou validé une demande inattendue ? APPELEZ. Pas de reproche : la vitesse compte.

Signes d'alerte : courriel « document partagé », « facture », « mot de passe expiré » avec lien de connexion ; demande MFA que vous n'avez pas déclenchée ; client qui vous répond à un message que vous n'avez pas envoyé ; demande urgente de changement de RIB ou de virement « confidentiel ».

SALARIÉ — à faire	SALARIÉ — à ne pas faire
Appeler le RI **par téléphone**	Prévenir uniquement par courriel
Noter l'heure et ce que vous avez fait	Supprimer le courriel suspect (le signaler d'abord)
Signaler le courriel avec « Signaler l'hameçonnage »	Transférer le courriel à des collègues
Rester disponible pour le RI	Payer ou changer un RIB sans vérification par téléphone

RESPONSABLE INCIDENT — dans les 30 minutes

1. □ Ouvrir le registre (heure, compte, constat) ; fixer la gravité (S1 si virement en jeu).
2. □ Réinitialiser le mot de passe, **déconnecter toutes les sessions**.
3. □ Révoquer applications tierces inconnues et mots de passe d'application ; vérifier les méthodes MFA.
4. □ Capturer **puis** supprimer : transferts, filtres, délégations, réponse automatique.
5. □ Exporter le journal de connexions ; enregistrer le courriel au format original (`.eml`).
6. □ Purger le courriel des autres boîtes ; bloquer expéditeur / domaine.
7. □ Paiement en jeu : **banque (service fraude) immédiatement**, client appelé sur son numéro connu.
8. □ Données personnelles exposées : référent données (CNDP recommandé).

Clôture : MFA forte activée, 14 jours sans activité suspecte, correspondants informés, retour d'expérience planifié.

Contact de crise	Numéro / référence
Gérant (directeur de crise) / RAF (suppléant)	[_____] / [_____]
Prestataire IT (astreinte) / hébergeur (n° contrat)	[_____] / [_____]
Banque — service fraude / avocat	[_____] / [_____]
maCERT (DGSSI) — signalement volontaire / police (19)	[à vérifier sur dgssi.gov.ma] / 19

FICHE RÉFLEXE B — Rançongiciel (fichiers chiffrés, note de rançon)

Numéro d'alerte : RI [_____] — prestataire [_____] — gérant [_____]

Fichiers qui ne s'ouvrent plus, extension inconnue, message de rançon ? DÉBRANCHEZ LE RÉSEAU, N'ÉTEIGNEZ PAS, APPELEZ.

Signes d'alerte : fichiers renommés avec une extension inconnue ; fichier `LISEZ-MOI` / `HOW_TO_DECRYPT` dans les dossiers ; fond d'écran remplacé ; alerte Defender « rançongiciel » ou antivirus désactivé ; PC ou NAS anormalement lents avec le disque qui tourne sans arrêt.

SALARIÉ — à faire	SALARIÉ — à ne pas faire
Débrancher le câble réseau, couper le Wi-Fi	Éteindre ou redémarrer le PC
Appeler le RI immédiatement	Brancher une clé USB ou un disque pour « sauver » des fichiers
Photographier l'écran (note de rançon)	Répondre à l'attaquant, payer
Laisser le PC tel quel, poser une étiquette rouge	En parler à l'extérieur ou sur les réseaux sociaux

RESPONSABLE INCIDENT — dans les 30 minutes

1. □ Isoler chaque poste touché ; **couper le NAS du réseau** ; **débrancher le disque de sauvegarde USB**.
2. □ Suspendre les synchronisations cloud ; bloquer les accès distants (bureau à distance, télémaintenance).
3. □ Classer S1/S2 ; appeler le gérant et le prestataire ; activer le **groupe de crise hors bande**.
4. □ Registre : postes touchés, heures, comptes, décisions (dont « éteindre ou non »).
5. □ Vérifier la dernière sauvegarde **hors ligne / hors site** saine (date, intégrité).
6. □ Désactiver les comptes utilisés ; changer les mots de passe **depuis un poste sain**.
7. □ Conserver note, fichiers chiffrés, courriels de l'attaquant (SHA-256, chaîne de possession).
8. □ Gérant + avocat : refus de payer par défaut ; plainte ; CNDP si vol de données (recommandé) ; maCERT (volontaire).

Ne jamais reconnecter un poste non réinstallé. Restaurer par priorité : facturation → commandes → dossiers → archives.

Contact de crise	Numéro / référence
Gérant (directeur de crise) / RAF (suppléant)	[_____] / [_____]
Prestataire IT (astreinte) / hébergeur (n° contrat)	[_____] / [_____]
Banque — service fraude / avocat	[_____] / [_____]
maCERT (DGSSI) — signalement volontaire / police (19)	[à vérifier sur dgssi.gov.ma] / 19

FICHE RÉFLEXE C — Site e-commerce piraté

Numéro d'alerte : RI [_____] — hébergeur (support + n° contrat) [_____] — gérant [_____]

Page modifiée, redirection, alerte « site dangereux », client qui signale un problème ? CAPTUREZ L'ÉCRAN ET APPELEZ LE RI.

Signes d'alerte : page d'accueil remplacée ; redirection vers un autre site ; alerte « site dangereux » du navigateur ou de Google Search Console ; formulaire de carte bancaire sur notre site (il ne doit jamais y en avoir) ; courriel de l'hébergeur signalant un abus ; clients qui reçoivent des hameçonnages citant leurs commandes.

SALARIÉ — à faire	SALARIÉ — à ne pas faire
Faire une capture (URL, date, heure)	Se connecter à l'administration du site pour « réparer »
Appeler le RI	Répondre publiquement aux clients ou sur les réseaux
Prendre les commandes par téléphone	Promettre qu'« aucune donnée n'a été touchée »

RESPONSABLE INCIDENT — dans les 2 heures

1. □ Registre ; variante : défiguration / fichier suspect (web shell) / script injecté / fuite de données.
2. □ Appeler l'hébergeur : **instantané fichiers + base à l'état actuel** et export des journaux, **avant** tout nettoyage.
3. □ Mettre le site **en maintenance** (ou suspension par l'hébergeur).
4. □ Changer **tous** les accès depuis un poste sain : panneau d'hébergement, FTP/SFTP/SSH, admins boutique, utilisateur MariaDB, clés d'API.
5. □ Capturer puis supprimer les comptes admin inconnus.
6. □ Paiement possiblement concerné : prévenir **le prestataire de paiement** sans délai (S1).
7. □ Données clients possiblement exposées : référent données + avocat (CNDP recommandé, RGPD si clients UE).
8. □ Reconstruire depuis le **code de référence** et une **sauvegarde saine**, après correction de la faille.

Remise en ligne seulement après : faille corrigée, secrets changés, fichiers vérifiés, page de paiement contrôlée. Surveillance 30 jours.

Contact de crise	Numéro / référence
Gérant (directeur de crise) / RAF (suppléant)	[_____] / [_____]
Prestataire IT (astreinte) / hébergeur (n° contrat)	[_____] / [_____]
Banque — service fraude / avocat	[_____] / [_____]
maCERT (DGSSI) — signalement volontaire / police (19)	[à vérifier sur dgssi.gov.ma] / 19